AI4DEVS

AI
PROYECTOS LEGACY

Auditar un sistema que ya existe

Sesión 6 · Máster AI4Devs · LIDR Academy

AI4DEVS

ANTES DE EMPEZAR

Esta sesión se está grabando

Para cumplir con el GDPR, tenemos que informarte de que la sesión está siendo grabada y que podemos utilizarla (de forma anónima) para promocionar nuestras formaciones.

Si prefieres no salir, mantén la cámara apagada.



AI4DEVS

TU MENTOR HOY

John Roa

VP of Engineering · GenLogs

18+ años en industria de software
12+ años liderando equipos de tecnología
Escaló una compañia Fintech de 6 a 60+ ingenieros como VP of Engineering
Consultor Startup scalability & tech leadership
Chief Organizer de Pycon Colombia Top 5 Python Conference in LATAM



https://www.linkedin.com/in/johnroa27/

BLOQUE 1

El puente

La tarea que trajisteis es el material de hoy.

AI4DEVS

EL PUENTE

Vuestros dos números

- El primero lo produce una máquina en dos minutos, y crece gratis.
- El segundo lo produce una persona abriendo archivos, y no escala.
- El que manda es el segundo: es el ancho real de vuestra tubería.
- Y decidirlo antes de lanzar nada es lo que cambia el tamaño del encargo.

AI4DEVS

AGENDA

Cómo va a fluir esta sesión

1 El puente: vuestros dos números

2 El marco: presupuesto de verificación y rebanadas

3 DEMO 1 · auditar, y el resultado no lo controla nadie

. Break

4 Qué hace priorizable a un hallazgo

5 DEMO 2 · ordenar, que es lo que no se delega

6 DEMO 3 · dónde vive el rigor de lo que no escribes

7 El artefacto, y solo la punta al tablero

DEMO 1

Auditar

Dos minutos y una lista larga. Vamos a ver de qué está hecha.

AI4DEVS

EL MARCO

Encontrar es barato, comprobar es el cuello

- Un agente normalmente devuelve una lista extensa, incluso sobre código con buenas practicas.
- Comprobar cuesta minutos de persona, y ese es el recurso escaso.

AI4DEVS

EL MARCO

El tamaño de una auditoría es propiedad de cómo la cortaste

- Los mismos defectos dan una lista enorme o una corta, según dónde pongas el corte.
- Dos hallazgos que son el mismo solo se reconocen si están uno al lado del otro.
- Auditoría global ?

AI4DEVS

DEMO 1

La severidad no es un dato del sistema

- Seis corridas del mismo prompt, sobre el mismo código y con el mismo modelo.
- Devolvieron 12, 13, 10, 11, 13 y 14 hallazgos.
- El mismo defecto salió el 9.º, el 10.º, el 3.º, el 5.º y el 6.º.
- Y uno de ellos no desapareció: apareció absorbido dentro de otro.
- Todos los órdenes son defendibles. Por eso hace falta un criterio de fuera.

SI TE LLEVAS UNA SOLA COSA DE LA DEMO 1

Encontrar ya es gratis. Ordenar, no.

y el orden es lo único que te dice qué se hace el lunes


BREAK
Volvemos con la parte que no se delega

DEMO 2

Ordenar

La lista ya está. Ahora empieza el trabajo.

AI4DEVS

EL CRITERIO

Una auditoría devuelve tres cosas mezcladas

- Hecho: «esta ruta devuelve la entidad entera, con el correo dentro». Se abre y se mira.
- Riesgo: «si alguien añade un campo, saldrá sin que nadie lo decida». Vale lo que valga el hecho.
- Opinión: «aquí convendría una caché». No se comprueba, no se deriva, no se refuta sin medir.
- Solo los hechos y los riesgos llevan prioridad. Una opinión lleva un experimento.

AI4DEVS

EL CRITERIO

Cuatro ejes que se responden con un hecho

- Daño: qué se rompe, y quién lo nota.
- Radio: cuántos sitios hay que tocar a la vez, contados y listados, nunca «varios».
- Reversibilidad: ¿lo deshace un revert limpio, o deja rastro en datos ya guardados?
- Precedencia: ¿su arreglo abarata o encarece el de otro hallazgo, y cuál?

AI4DEVS

DEMO 2

Dos claves, y en este orden

- Primera, precedencia: es un orden topológico, no un juicio. Si el arreglo de A abarata el de B, A va antes y no se discute.
- Segunda, dentro de cada nivel: daño dividido por radio. No daño a secas.
- La división es lo que impide que lo pequeño y molesto se quede nueve años sin arreglar por no ser nunca lo más grave del día.

AI4DEVS

DEMO 2

Cuando el daño y la precedencia chocan

- Subirlo cuesta escribir el arreglo dos veces, contra un modelo que todavía va a cambiar.
- Bajarlo deja el daño abierto semanas, y era lo más grave de la lista.
- Ninguna de las dos: el hallazgo se parte en contención y arreglo.
- Y la lista acaba con una fila más, no con una menos.

SI TE LLEVAS UNA SOLA COSA DE LA DEMO 2

Lo más grave no va primero.

y cuando el daño y la precedencia chocan, la salida no es mover la fila

DEMO 2

Ordenar (Bonus)

Common Vulnerability Scoring System (CVSS)

marco estandarizado para medir la severidad de las fallas de seguridad en los sistemas de información

DEMO 3

Dónde vive el rigor

Una línea puede ser un encargo excelente o un desastre, y la diferencia no está en la línea.

GRACIAS

Encontrar es barato. Ordenar es el trabajo.

ROTI

Antes de iros: puntuad la sesión de 1 a 5 y decidnos qué os habríais llevado y no os lleváis.



AI4DEVS

DEMO 3

Tres sitios, tres garantías distintas

- La arquitectura objetivo, en el archivo de instrucciones: responde «¿hacia dónde vamos?», y aquí el código no la enseña.
- El ritual, en un comando: responde «¿cómo se hace un encargo aquí?», y hace que el encargo cuarenta se parezca al primero.
- La comprobación, en un hook: responde «¿qué no se puede guardar?», y es la única que no decide un modelo.

AI4DEVS

DEMO 3

Un arnés copiado de un proyecto sano bloquea el primer commit de uno heredado

- Los arneses que circulan afirman sobre el estado: «la suite pasa entera», «la cobertura no baja del 80 %».
- Sobre un sistema heredado las dos son falsas antes de que toques nada.
- El primer commit no entra, alguien lo salta «solo por esta vez», y a los tres días el hook está apagado.
- No lo mató un mal diseño: lo mató afirmar sobre el estado en vez de sobre el cambio.

SI TE LLEVAS UNA SOLA COSA DE LA DEMO 3

Un prompt corto es uno cuyo contexto vive escrito en otro sitio.

cuando te repitas tres veces, eso ya no es un prompt: es una regla del proyecto

AI4DEVS

CIERRE DEL DÍA

El artefacto es el archivo, no el tablero

- La auditoría entera va versionada, junto al código que describe.
- Al gestor de tareas sube solo lo que alguien va a coger esta semana.
- Un tablero con cuarenta hallazgos no es un plan: es un cementerio.
- Y lo que sube, sube con su cita.